BSCP: REVIEW + PREPARATION

&

METHODOLOGY

by whymir

-$ cat whymir.md

- Security Consultant
- RE: UN1ON member
- Malaysia Cybersecurity Camp (MCC) Alumni & Agent
- Pokémon Card Collectors

WHAT IS THE BSCP?

BSCP - Burp Suite Certified Practitioner, created by PortSwigger's Web Security Academy. (known as Burp Suite makers)

- Test your knowledge of web applications.
- Completely free through their academy/modules.
- Includes more than 240 labs covering over 20 web vulnerabilities, including XSS, Web Cache Poisoning, SSRF, and more.
- 4 hours to solve 2 web applications.
- Each web application contains 3 stages.

Certificate:

Burp Suite Certified Practitioner

LEARNING PATH IN BSCP

All learning paths

My progress 38 of 38 Completed on 06 Jan 2026

PRACTITIONER

Web cache deception

This learning path covers web cache deception vulnerabilities. You'll learn how to identify discrepancies between how the origin server and cache handle requests and how to leverage the discrepancies to create path confusion.

View path → RESTART PATH

My progress 19 of 19 Completed on 06 Mar 2026

PRACTITIONER

WebSockets vulnerabilities

This learning path covers the identification and exploitation of security vulnerabilities specific to WebSockets in web applications.

View path → RESTART PATH

My progress 0 of 55

PRACTITIONER

Authentication vulnerabilities

This learning path explores authentication vulnerabilities, which have a critical impact on security. You'll learn about common mechanisms and vulnerabilities, and strategies for robust authentication.

View path → GET STARTED →

My progress 0 of 23

PRACTITIONER

Server-side request forgery (SSRF) attacks

This learning path teaches you about server-side request forgery (SSRF). You'll learn about its impact, common techniques used in attacks, and how to defend against them.

View path → GET STARTED →

My progress 0 of 65

PRACTITIONER

Prototype pollution

This learning path introduces you to prototype pollution vulnerabilities in JavaScript. You'll learn what prototype pollution is, how it can be exploited, and how to prevent it in your applications.

View path → GET STARTED →

My progress 19 of 19 Completed on 07 Oct 2025

PRACTITIONER

Clickjacking (UI redressing)

This learning path deals with clickjacking attacks. You'll learn the fundamentals of clickjacking, how to construct basic attacks, and implement server-side and client-side defense strategies.

View path → RESTART PATH

My progress 52 of 52 Completed on 17 Sept 2025

APPRENTICE

Server-side vulnerabilities

This learning path introduces you to a range of common server-side vulnerabilities. This is perfect if you're new to web security and want to get an overview of the kinds of vulnerabilities that exist, as well as how an attacker might identify and exploit them in real-world systems.

View path → RESTART PATH

My progress 51 of 51 Completed on 08 Sept 2025

PRACTITIONER

SQL injection

This learning path introduces SQL injection (SQLi), a critical web vulnerability. You'll learn how to detect and exploit SQLi to uncover hidden data and manipulate application behavior, as well as essential techniques to secure applications against SQLi attacks.

View path → RESTART PATH

My progress 0 of 29

PRACTITIONER

GraphQL API vulnerabilities

This learning path explores common vulnerabilities associated with GraphQL APIs due to implementation and design flaws. You'll learn how to find GraphQL endpoints, bypass some common defenses, and exploit a range of GraphQL API vulnerabilities.

View path → GET STARTED →

My progress 0 of 21

PRACTITIONER

Cross-origin resource sharing (CORS)

This learning path provides an in-depth understanding of CORS, including common examples of CORS-based attacks and how to protect against these attacks.

View path → GET STARTED →

My progress 14 of 14 Completed on 18 Sept 2025

PRACTITIONER

Path traversal

This learning path covers path traversal vulnerabilities. You'll learn how to carry out path traversal attacks and circumvent common obstacles. You'll also learn how to prevent path traversal attacks.

View path → RESTART PATH

My progress 0 of 24

PRACTITIONER

NoSQL injection

This learning path covers the detection, exploitation, and prevention of NoSQL injection vulnerabilities. You'll explore the differences between NoSQL and SQL injection, learn how to perform NoSQL syntax injection, and how to use NoSQL operators to manipulate queries.

View path → GET STARTED →

My progress 29 of 29 Completed on 06 Mar 2026

PRACTITIONER

Race conditions

This learning path covers race conditions, a common vulnerability in web applications where concurrent processes lead to unintended behavior. You'll learn how to identify, exploit, and prevent race conditions, leveraging tools like Burp Suite's Repeater and the Turbo Intruder extension.

View path → RESTART PATH

My progress 49 of 49 Completed on 07 Oct 2025

PRACTITIONER

Cross-site request forgery (CSRF)

This learning path covers CSRF (Cross-Site Request Forgery). You'll learn about some common CSRF vulnerabilities, and how to prevent them.

View path → RESTART PATH

My progress 35 of 35 Completed on 18 Sept 2025

PRACTITIONER

File upload vulnerabilities

In this learning path, you'll explore how simple file upload functions can become a vector for severe attacks. You'll learn how to bypass common defense mechanisms to upload a web shell, enabling full control over a vulnerable web server.

My progress 17 of 17 Completed on 18 Sept 2025

PRACTITIONER

Web LLM attacks

This learning path teaches you how to perform attacks using Large Language Models (LLMs). You'll learn how to construct attacks that take advantage of an LLM's access to data, API, and user information that you would not be able to access directly.

My progress 29 of 29 Completed on 18 Sept 2025

PRACTITIONER

API testing

This learning path teaches you how to test APIs that aren't fully used by the website front-end. You'll learn key API recon skills to help you discover more attack surface. In addition, you'll learn how to identify server-side parameter pollution vulnerabilities that may impact internal APIs.

BSCP OVERVIEW

Price: $99.00 (RM 392.44)

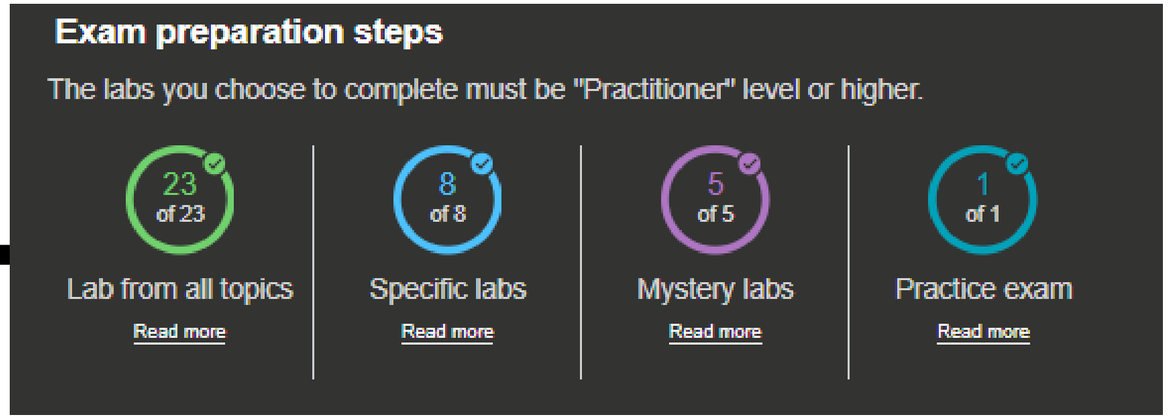
Expires: Yes (5 years)

Proctoring: Yes (Recording + Share Screen)

Retake: No. You need to buy new one

Exam Requirements:

1. Burp Suite Professional (Burp Pro)
2. Complete neccesary lab require



MY REVIEW?

- Why BSCP?
- It takes me almost 6 months to grind all the modules and the lab with other commitments.
- The most Challenging part? Not the exam.
- Exam difficulty = fair (not too hard)
- Time? Fair (assume 45min each vuln)
- Note-taking is important.

EXAM PREPARATION?

- Complete the PortSwigger Web Security Academy modules partially or fully.
- Solve Mystery Labs to practice random scenarios without hints.
- Repeat the recommended labs until you can solve them quickly without relying on walkthroughs.
- Take the practice exam without looking at any solutions or hints.
- Prepare your tools, cheat sheets, payloads, extensions, plugins, and workflow in advance.
- Make sure you are comfortable using Burp Suite Professional features such as Repeater, Intruder, Collaborator, Scanner, and extensions.

METHODOLOGY?

- Stage 1: Access any user account.
- Stage 2: Elevate to administrator
- Stage 3: Read Carlos ' secret.

Important Note:

- At least 1 active user
- Every 15 seconds, a victim visits the homepage
- SSRF is always running on port 6566

METHODOLOGY?

Stage 1: Access any user account.

- Cross-Site Scripting
- Authentication / Credentials Brute force
- HTTP Request Smuggling
- Web Cache Poisoning
- Host Header Injection
- DOM-XSS
- SQL Injection

METHODOLOGY?

Stage 2: Elevate to administrator.

- Password Reset
- Cross-Site Request Forgery (CSRF > ATO)
- SQL Injection
- JWT
- Server-Side Request Forgery
- Access Control vulnerabilities
- CORS
- Prototype Pollution

METHODOLOGY?

Stage 3: Read Carlos Secret.

- XXE
- SSRF
- SSTI
- LFI
- File Uploads
- OS Command Injection
- Insecure Deserialization

TIPS & TRICK

Running Active Scan++

Prepare cheatsheet.

Burp configuration & extensions

Notes

Burp Project file <-- Important!!!

Protor issue?

CONCLUSIONS

- Stay consistent and practice regularly.
- Do not get discouraged if you struggle with certain vulnerabilities at first.

- Good luck on your journey toward the BSCP certification.

THANK YOU